SAVEETHA INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES

SIMATS Engineering • Department of Information Technology

ASSESSMENT TOOL II – ASSIGNMENT (CO1-AT3)

Student Name:	**NITHISH**	**Register Number:**	**192521249**
Course Name:	Ethical Hacking	**Course Code:**	ITA14

> **Course Outcome (CO1):** Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Question 1: Informal Authorization & Out-of-Scope Vulnerability

> *"A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles."*

Decision: No, under no circumstances should the vulnerability be exploited.

Justification Grounded in Ethical & Legal Principles:

1. **Absence of Valid Authorization & Scoping:** A one-line email authorization does not satisfy the legal prerequisite of mutual consent. Professional ethical hacking mandates a formal, legally enforceable document (e.g., Rules of Engagement [RoE], Non-Disclosure Agreement [NDA], and explicit Statement of Work [SOW]) specifying IP addresses, target domains, testing windows, and approved attack vectors. Without formal scoping, exploitation equates to unauthorized computer access under laws such as India's IT Act (Section 43/66) or the US Computer Fraud and Abuse Act (CFAA).
2. **Principle of Non-Maleficence (Do No Harm):** Exploiting an uncharacterized, out-of-scope system creates immediate risks of system instability, unintended denial of service, corrupted data records, or unintended exposure of sensitive customer or proprietary assets.
3. **Integrity and Boundaries:** Ethical hackers differentiate themselves from malicious threat actors by strictly respecting operational boundaries. Exploiting an asset simply because it is vulnerable violates the fundamental standard of professional integrity.

Required Course of Action: Immediately halt active probes against the unlisted system. Document the discovered vulnerability with non-intrusive metadata (IP address, open port, software banner, passive detection timestamp). Promptly notify the client's designated point of contact (POC) through an out-of-band, encrypted channel. Present the preliminary finding as an urgent advisory and request explicit, written scope expansion before executing any validation procedures.

Question 2: Production Database & SQL Injection Safety

> *"You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?"*

Operational Procedure (Zero Harm Protocol):

Upon identifying that the SQL injection (SQLi) vector interacts directly with live financial records, active payload execution must immediately transition to a safe, controlled validation posture:

- **Do NOT extract sensitive financial tables** (e.g., avoid `UNION SELECT` queries targeting credit card numbers, transaction ledgers, or account hashes). Exfiltrating real financial records violates data privacy mandates (PCI-DSS, GDPR, RBI regulations) and creates massive client liability.
- **Use Non-Destructive Proof of Concept (PoC):** Validate vulnerability existence using benign, deterministic proofs — such as executing harmless database built-ins (e.g., querying database version `SELECT @@version`, calculating

- **Immediate Responsible Disclosure:** Document the exact vulnerable parameter, proof of syntax evaluation, and reproduction steps with sanitized screenshots. Issue an urgent interim vulnerability report to the client's security lead so immediate parameterization or WAF virtual patching can be deployed.

Pre-Engagement Precautions That Should Have Been Implemented:

1. **Environment Segregation:** Scoping agreements should mandate testing against a dedicated staging, UAT, or sanitized clone containing synthetic mock records rather than live production databases.
2. **Pre-Test Backup Verification:** Mandatory verification of recent, validated system backups and snapshot rollback capabilities prior to conducting high-risk database tests.
3. **Explicit RoE Protocols:** Formal documentation defining exact procedures for handling sensitive findings, specifying that exploitation ceases the moment sensitive production data exposure is confirmed.

Question 3: Accidental Denial-of-Service (DoS) and Remediation

> *"During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now."*

Preventative Measures That Should Have Been Enforced:

- **Rate Limiting and Concurrency Caps:** Automated scanners (e.g., Nuclei, Burp Suite, Nessus) must be calibrated to throttled request rates (e.g., 5–10 requests/sec) to avoid thread exhaustion and memory overflow on fragile web servers.
- **Exclusion of Volatile Payloads:** High-risk tests—including heavy recursive fuzzing, memory exhaustion checks, fork-bomb vectors, and intensive timing payloads—must be explicitly filtered out of automated suites during live production assessments.
- **Staggered & Off-Peak Testing Windows:** Scheduling intensive testing exclusively during designated maintenance windows or low-traffic periods (e.g., midnight to 4:00 AM) with standby technical support.
- **Continuous Health Monitoring:** Running an out-of-band HTTP latency monitor (ping/heartbeat probe) to detect performance degradation before total service collapse.

Immediate Professional & Ethical Responsibilities:

1. **Immediate Test Termination:** Kill all active scanning scripts, exploit payloads, and automated tools instantly.
2. **Emergency Point-of-Contact Escalation:** Immediately notify the primary client liaison and infrastructure team via direct phone call (followed by documented email), stating the exact timestamp, target IP, and triggering request string.
3. **Collaborative Incident Remediation:** Provide server administrators with full raw execution logs, source IP addresses, and payload mechanics to assist them in isolating stuck processes, clearing connection pools, or rebooting dependencies.
4. **Post-Incident Root Cause Analysis (RCA):** Prepare an objective incident brief explaining how the benign probe induced the outage (e.g., unindexed query triggering CPU lockup), provide remediation advice to harden system resilience against real attackers, and obtain formal re-authorization before resuming testing.

Question 4: Covert Testing Without IT Department Knowledge

> *"A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?"*

Ethical and Practical Risks:

- **Unintended Real-World Escalation:** The defending IT team may mistake the penetration test for a nation-state or ransomware breach, initiating aggressive incident response protocols (e.g., severing external network uplinks, taking production databases offline, or engaging federal law enforcement).
- **Legal Liability & Accusations of Malice:** If an unrelated outage, hardware fault, or concurrent real-world

Engagement Structuring & Self-Protection Framework:

- **Executive-Level Authorization:** Testing must be authorized in writing by C-suite executives possessing legitimate legal authority over all enterprise assets (e.g., CEO, CIO, CISO, or General Counsel).
- **Designated White-Cell / Trusted Agent:** Establish a confidential "White Cell"—a select senior IT/security leader who maintains operational awareness, deconflicts false alarms, and can halt defensive escalation if necessary.
- **Formal "Get Out of Jail Free" Letter:** Testers must carry signed authorization credentials on corporate letterhead, detailing tester identities, phone verification numbers for executive leadership, testing validity dates, and legal scope.
- **Emergency Deconfliction Protocol:** Establish a secure, dedicated communication channel and pre-agreed code-words to instantly verify whether anomalous network activity originates from the test team or an actual adversary.

Question 5: Red Team Exercise vs. Vulnerability Assessment

> *"You're asked to perform a 'red team' exercise versus a 'vulnerability assessment.' Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two."*

Dimension	Vulnerability Assessment (VA)	Red Team Exercise (Adversary Emulation)
Primary Objective	Comprehensive breadth: Identify, catalog, and rank as many known vulnerabilities as possible across all assets.	Specific depth & goal: Test the bank's detection, response, and resilience against a full multi-vector adversary campaign.
Methodology & Scope	Cooperative, planned, and transparent. Automated scanners and systematic manual reviews across known network ranges and server builds.	Covert, goal-driven, and multi-layered. Emulates Advanced Persistent Threats (APTs) combining physical, social, and cyber vectors.
Physical Security Testing	Audit-oriented: Inspecting door lock specs, badge reader logs, server room camera coverage, and biometric compliance checklists.	Active infiltration: Social engineering front-desk staff, tailgating into staff zones, lock-picking, planting rogue drop-boxes behind teller desks.
Ethics & Rules of Engagement (RoE)	Strictly technical and non-intrusive. Zero social engineering; operations coordinated openly with internal IT and branch administrators.	Carefully bounded aggression: Social engineering allowed (phishing/vishing), but explicit restrictions on coercing low-level staff, damaging infrastructure, or accessing real customer banking records.

Bank Scenario Summary: In a bank context, a *Vulnerability Assessment* ensures that the core banking web app, ATMs, and branch firewalls have no missing patches or misconfigurations. In contrast, a *Red Team Exercise* determines whether an operative can spear-phish a loan officer, pivot into the SWIFT transfer network, physically bypass branch security after hours to plant a packet sniffer, and evaluate how rapidly the Security Operations Center (SOC) detects and neutralizes the breach.

ACADEMIC INTEGRITY CODE OF CONDUCT

I, **NITHISH (Reg. No: 192521249)**, certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action under university regulations.

NITHISH	**192521249**	**October 26, 2026**
Student Signature / Name	Register Number	Submission Date